

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG  
KHOA AN TOÀN THÔNG TIN**



**BÁO CÁO BÀI THỰC HÀNH  
HỌC PHẦN: THỰC TẬP CƠ SỞ  
MÃ HỌC PHẦN: INT13147**

**BÀI THỰC HÀNH 3.2  
TẤN CÔNG VÀO MẬT KHẨU**

Sinh viên thực hiện:

B22DCAT107 Nguyễn Đức Hải

Giảng viên hướng dẫn: PGS. TS. Hoàng Xuân Dậu

**HỌC KỲ 2 NĂM HỌC 2024-2025**

# MỤC LỤC

|                                                            |    |
|------------------------------------------------------------|----|
| MỤC LỤC.....                                               | 2  |
| DANH MỤC CÁC HÌNH VẼ.....                                  | 3  |
| DANH MỤC CÁC TỪ VIẾT TẮT.....                              | 4  |
| <b>CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH</b> .....   | 5  |
| 1.1 Mục đích.....                                          | 5  |
| 1.2 Tìm hiểu lý thuyết .....                               | 5  |
| <b>1.2.1</b> Công cụ Ophcrack.....                         | 5  |
| <b>1.2.2</b> Công cụ PWDUMP .....                          | 6  |
| <b>1.2.3</b> Công cụ John the Ripper .....                 | 7  |
| <b>CHƯƠNG 2. NỘI DUNG THỰC HÀNH</b> .....                  | 9  |
| 2.1 Chuẩn bị môi trường .....                              | 9  |
| 2.2 Các bước thực hiện.....                                | 9  |
| <b>2.2.1</b> Crack mật khẩu trên hệ điều hành Windows..... | 9  |
| <b>2.2.2</b> Crack mật khẩu trên hệ điều hành Linux .....  | 14 |
| TÀI LIỆU THAM KHẢO.....                                    | 17 |

## DANH MỤC CÁC HÌNH VẼ

|                                                  |    |
|--------------------------------------------------|----|
| Hình 1 – Cài đặt công cụ PWDUMP8 .....           | 9  |
| Hình 2 – Cài đặt công cụ Ophcrack .....          | 9  |
| Hình 3 – Cài đặt table dùng cho Ophcrack .....   | 10 |
| Hình 4 – Cài đặt thành công các công cụ .....    | 10 |
| Hình 5 – Tạo các user theo yêu cầu .....         | 11 |
| Hình 6 – Sử dụng công cụ PWDUMP8 .....           | 11 |
| Hình 7 – Lưu các hàm băm ra file.....            | 12 |
| Hình 8 – Load file được tạo vào Ophcrack .....   | 12 |
| Hình 9 – Insert table vào Ophcrack.....          | 13 |
| Hình 10 – Bắt đầu bẻ khóa mật khẩu .....         | 13 |
| Hình 11 – Kết quả sau khi chạy Ophcrack.....     | 14 |
| Hình 12 – Tạo các user theo yêu cầu .....        | 14 |
| Hình 13 – Kết hợp 2 file passwd và shadow .....  | 15 |
| Hình 14 – Crack thành công mật khẩu 8 kí tự..... | 15 |
| Hình 15 – Crack thành công mật khẩu 6 kí tự..... | 16 |
| Hình 16 – Crack thành công mật khẩu 4 kí tự..... | 16 |

## DANH MỤC CÁC TỪ VIẾT TẮT

| <b>Từ viết tắt</b> | <b>Thuật ngữ tiếng Anh/Giải thích</b> | <b>Thuật ngữ tiếng Việt/Giải thích</b>  |
|--------------------|---------------------------------------|-----------------------------------------|
| SAM                | Security Account Manager              | Trình quản lý tài khoản bảo mật         |
| LM Hash            | LAN Manager Hash                      | Thuật toán băm mật khẩu                 |
| LSASS              | Local Security Authority Subsystem    | Hệ thống con của cơ quan bảo mật cục bộ |
| JtR                | John the Ripper                       | Công cụ bẻ khóa mật khẩu                |
| DLL                | Dynamic Link Library                  | Thư viện liên kết động                  |

# CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH

## 1.1 Mục đích

Mục đích của bài thực hành “3.2: Tấn công vào mật khẩu” là:

- Hiểu được mối đe dọa về tấn công mật khẩu.
- Hiểu được nguyên tắc hoạt động của một số công cụ Crack mật khẩu trên các hệ điều hành Linux và Windows.
- Biết cách sử dụng công cụ để Crack mật khẩu trên các hệ điều hành Linux và Windows.

## 1.2 Tìm hiểu lý thuyết

### 1.2.1 Công cụ Ophcrack

Ophcrack là một công cụ hữu ích để khôi phục mật khẩu Windows bị quên, đặc biệt với mật khẩu đơn giản. Nó sử dụng bảng cầu vồng, một phương pháp tính toán trước để nhanh chóng tìm ra mật khẩu từ các giá trị băm (hashes). Công cụ này hỗ trợ nhiều nền tảng và có giao diện thân thiện, nhưng nó không hiệu quả với mật khẩu phức tạp hoặc dài hơn 14 ký tự.

**Các đặc điểm chính của Ophcrack:**

#### ▪ Sử dụng Rainbow Tables

- Ophcrack không dựa vào tấn công brute-force thông thường mà sử dụng Rainbow Tables - một phương pháp tra cứu hash giúp tăng tốc độ bẻ khóa đáng kể.
- Công cụ này hỗ trợ nhiều bảng Rainbow miễn phí, cho phép khôi phục hầu hết mật khẩu ngắn một cách nhanh chóng.

#### ▪ Khả năng khôi phục mật khẩu Windows

- Ophcrack có thể trích xuất và bẻ khóa mật khẩu từ Windows XP, Vista, 7, 8, 10, nhưng hiệu quả giảm dần trên các hệ điều hành mới do Microsoft đã loại bỏ LM Hash.
- Có thể khôi phục cả mật khẩu dạng số, chữ cái, ký tự đặc biệt nếu bảng Rainbow phù hợp được sử dụng.

#### ▪ Chạy trực tiếp từ USB/CD mà không cần truy cập Windows

- Phiên bản Ophcrack LiveCD cho phép bẻ khóa mật khẩu mà không cần đăng nhập vào hệ điều hành Windows.
- Thích hợp khi quên mật khẩu hoặc cần truy cập hệ thống bị khóa.

#### ▪ Hỗ trợ giao diện đồ họa dễ sử dụng

- Ophcrack có giao diện thân thiện, trực quan, giúp người dùng dễ dàng nhập dữ liệu và theo dõi tiến trình bẻ khóa mật khẩu.

## Cách hoạt động của Ophcrack

### ▪ Thu thập hash mật khẩu

- Ophcrack trích xuất hash mật khẩu từ tệp SAM trên Windows hoặc từ một bản sao lưu có sẵn.
- Nếu sử dụng LiveCD, nó tự động quét và lấy hash mà không cần đăng nhập.

### ▪ So sánh hash với Rainbow Tables

- Công cụ sử dụng Rainbow Tables để tìm các hash trùng khớp với mật khẩu cần bẻ khóa.
- Nếu hash của mật khẩu khớp với một hash đã có trong bảng, mật khẩu sẽ được khôi phục ngay lập tức.

### ▪ Hiển thị kết quả

- Sau khi bẻ khóa thành công, Ophcrack hiển thị mật khẩu trong giao diện của nó.
- Nếu mật khẩu quá phức tạp và không có trong bảng Rainbow, quá trình có thể mất nhiều thời gian hoặc thất bại.

## 1.2.2 Công cụ PWDUMP

PWDUMP là một công cụ dùng để trích xuất hash mật khẩu từ SAM (Security Account Manager) trên hệ điều hành Windows. Các hash này có thể được sử dụng để bẻ khóa mật khẩu bằng các công cụ như Ophcrack, John the Ripper, hoặc Hashcat.

PWDUMP được sử dụng rộng rãi cho các cuộc tấn công "pass-the-hash" hoặc để bẻ khóa mật khẩu trực tiếp bằng cách sử dụng các công cụ như John the Ripper hoặc Ophcrack. Để hoạt động, PWDUMP phải được chạy dưới tài khoản quản trị viên hoặc có quyền truy cập vào tài khoản quản trị viên trên máy tính nơi hash được trích xuất.

### ▪ Cách hoạt động

PWDUMP hoạt động theo hai cách chính:

- **Truy cập trực tiếp vào file SAM:** Công cụ truy cập trực tiếp vào file SAM để trích xuất hash, yêu cầu quyền quản trị viên.
- **Tiêm vào quá trình LSASS:** Một số phiên bản tiêm một DLL vào quá trình Local Security Authority Subsystem (LSASS) để trích xuất hash từ bộ nhớ, phương pháp này có thể hiệu quả hơn và ít bị phát hiện hơn.

### ▪ Lịch sử và phát triển

Công cụ PWDUMP bắt đầu từ phiên bản gốc phát triển vào năm 1997. Kể từ đó, nhiều phiên bản và biến thể đã được tạo ra bởi các nhà phát triển khác nhau để cải thiện chức năng và hỗ trợ các phiên bản Windows mới hơn. Một số phiên bản nổi bật bao gồm:

- **pwdump2 (2000):** Sử dụng kỹ thuật tiêm DLL, yêu cầu quyền SeDebugPrivilege.

- **pwdump6:** Một phiên bản cải tiến, trích xuất cả hash NTLM và LanMan, hiển thị lịch sử mật khẩu.
- **pwdump8:** Hỗ trợ hash mã hóa AES-128, hoạt động trên Windows 10 và các phiên bản sau.
- **Quarks PwDump:** Một công cụ mã nguồn mở, trích xuất cả thông tin Bitlocker và lịch sử hash.

### 1.2.3 Công cụ John the Ripper

John the Ripper (JtR) là một chương trình mã nguồn mở được thiết kế để bẻ khóa mật khẩu. Được phát triển lần đầu tiên vào năm 1996, nó đã trở thành một trong những công cụ phổ biến nhất cho những người làm công tác bảo mật, chuyên gia an ninh mạng, và cả những kẻ tấn công. Với khả năng xử lý nhiều thuật toán băm mật khẩu khác nhau, JtR có thể hỗ trợ bẻ khóa mật khẩu cho nhiều hệ điều hành và ứng dụng.

John the Ripper chủ yếu được sử dụng để kiểm tra sức mạnh mật khẩu và khôi phục mật khẩu bị quên, đặc biệt hữu ích cho quản trị viên hệ thống và chuyên gia bảo mật. Nó hoạt động bằng cách tạo ra các mật khẩu tiềm năng và so sánh hash của chúng với hash mục tiêu để tìm ra mật khẩu gốc. Công cụ này hỗ trợ hàng trăm loại hash và cipher, không chỉ giới hạn ở mật khẩu mà còn mở rộng đến lưu lượng mạng, khóa riêng mã hóa, hệ thống tệp, đĩa, lưu trữ, và tài liệu.

#### ▪ Nguyên lý hoạt động:

John the Ripper hoạt động bằng cách sử dụng các phương pháp tấn công khác nhau để bẻ khóa mật khẩu. Các phương pháp này bao gồm:

- **Tấn công Brute Force:** JtR thử nghiệm tất cả các khả năng mật khẩu có thể. Đây là phương pháp đơn giản nhưng rất tốn thời gian.
- **Dictionary Attack:** Sử dụng một danh sách mật khẩu phổ biến, JtR sẽ thử từng mật khẩu trong danh sách cho đến khi tìm ra mật khẩu đúng.
- **Tấn công thông minh:** JtR có khả năng tự động tối ưu hóa chiến lược bẻ khóa dựa trên các mẫu mật khẩu mà nó nhận diện.

#### ▪ Ứng dụng thực tế của John the Ripper

- **Kiểm tra tính bảo mật:** Một trong những ứng dụng chính của JtR là kiểm tra tính bảo mật của các mật khẩu trong hệ thống. Bằng cách xác định xem mật khẩu nào dễ bị bẻ khóa, tổ chức có thể thay đổi để tăng cường tính bảo mật.
- **Đào tạo và giáo dục:** John the Ripper cũng được sử dụng trong các khóa học về an ninh mạng để giúp sinh viên hiểu về cách mà các mật khẩu có thể bị bẻ khóa và cách phòng chống.
- **Phân tích an ninh:** Các chuyên gia bảo mật sử dụng JtR trong quá trình phân tích an ninh sau các cuộc tấn công để hiểu rõ hơn về lỗ hổng trong hệ thống và cải thiện các biện pháp phòng ngừa.

### ▪ Các tùy chọn tấn công của John the Ripper:

John the Ripper hoạt động bằng cách tạo ra các mật khẩu tiềm năng và kiểm tra xem hash của chúng có khớp với hash mục tiêu hay không. Các chế độ bẻ khóa khác nhau xác định cách tạo mật khẩu tiềm năng:

- **Wordlist Mode:** Sử dụng danh sách từ đã định nghĩa, hiệu quả với mật khẩu phổ biến hoặc dựa trên từ điển.
- **Incremental Mode:** Thực hiện tấn công brute-force, thử tất cả các tổ hợp ký tự, từ đơn giản đến phức tạp, nhưng có thể mất nhiều thời gian.
- **Single Crack Mode:** Tạo mật khẩu dựa trên thông tin người dùng như tên đăng nhập, tên thật, hoặc tên thư mục cá nhân, hữu ích khi mật khẩu liên quan đến dữ liệu cá nhân.
- **Markov Mode:** Sử dụng dữ liệu thống kê về mẫu mật khẩu để tạo ứng viên, hiệu quả với mật khẩu theo mẫu phổ biến.
- **Mask Mode:** Cho phép người dùng chỉ định mẫu cho mật khẩu, như độ dài hoặc loại ký tự (ví dụ: chữ số, ký tự đặc biệt), hữu ích khi biết một phần cấu trúc mật khẩu.



## CHƯƠNG 2. NỘI DUNG THỰC HÀNH

## 2.1 Chuẩn bị môi trường

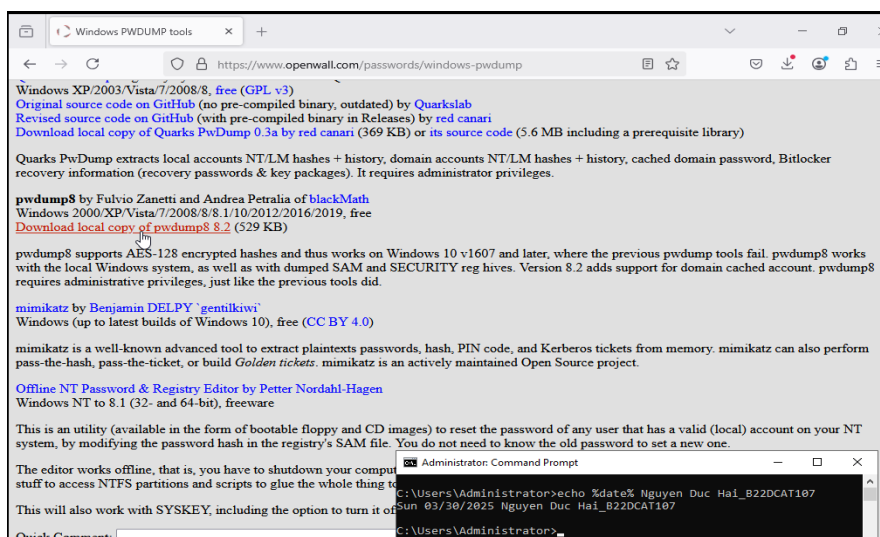
- Phần mềm VMWare Workstation hoặc Virtual Box hoặc các phần mềm ảo hóa khác.
- Phần mềm hệ điều hành Linux và Windows.
- Cài đặt các công cụ Crack mật khẩu trên hệ điều hành Linux.
- Cài đặt các công cụ Crack mật khẩu trên hệ điều hành Windows.

## 2.2 Các bước thực hiện

### 2.2.1 Crack mật khẩu trên hệ điều hành Windows

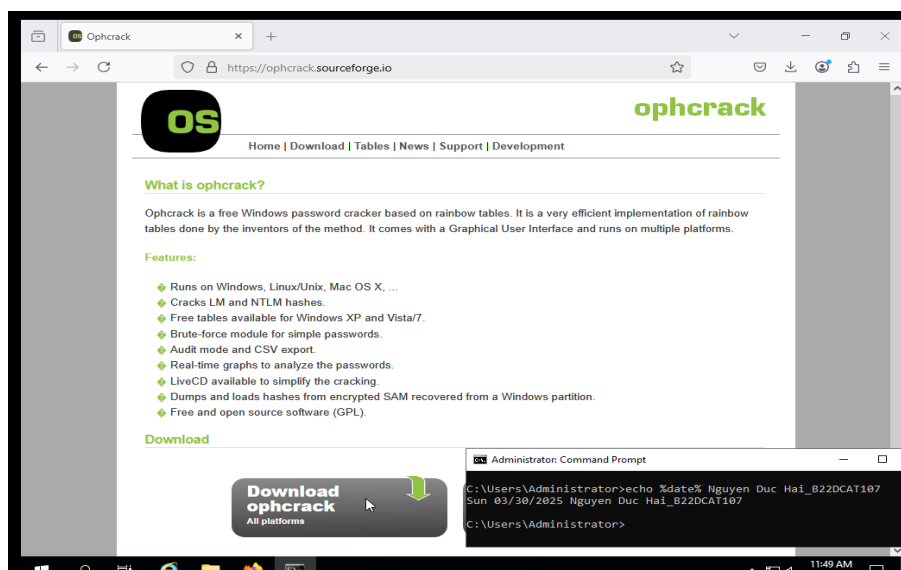
### Cài các công cụ cần thiết:

- **PWDUMP8.**



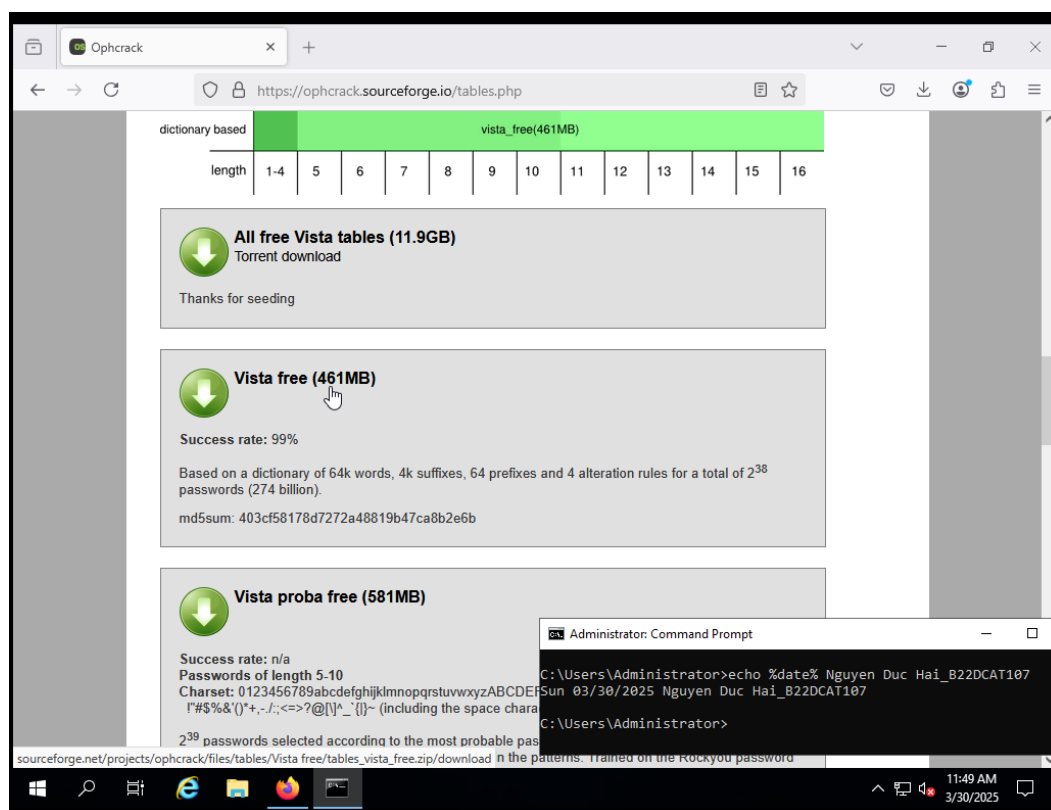
Hình 1 – Cài đặt công cụ PWDUMP8

- **Ophcrack.**



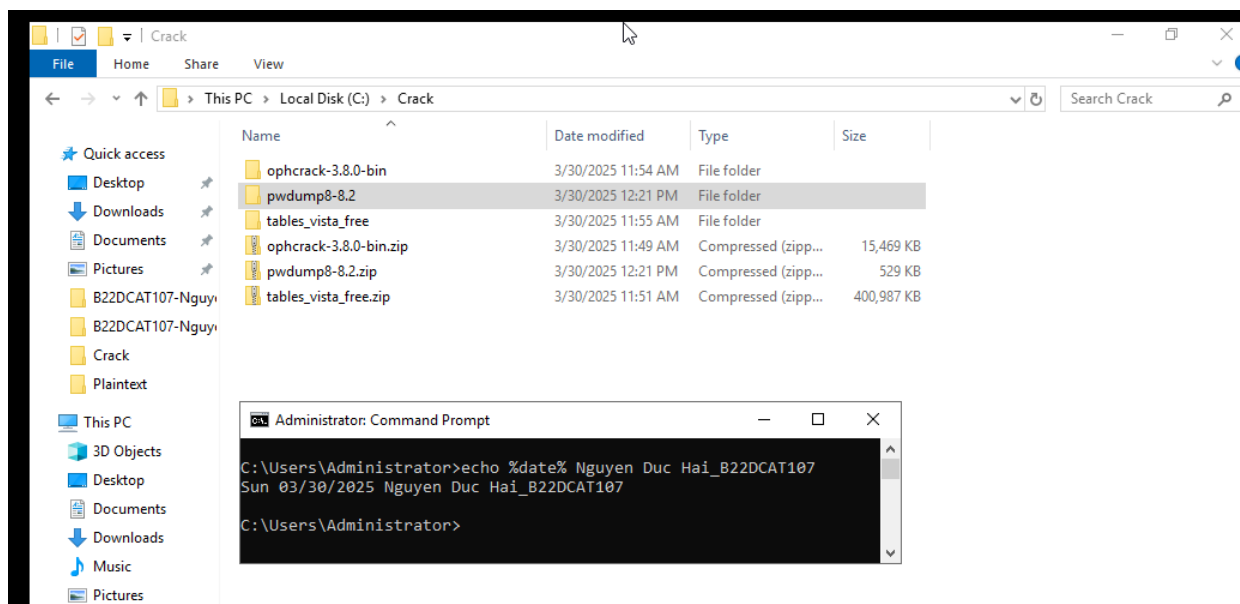
Hình 2 – Cài đặt công cụ Ophcrack

- Cài đặt table sử dụng cho Ophcrack.



Hình 3 – Cài đặt table dùng cho Ophcrack

Giải nén các file vừa tải.

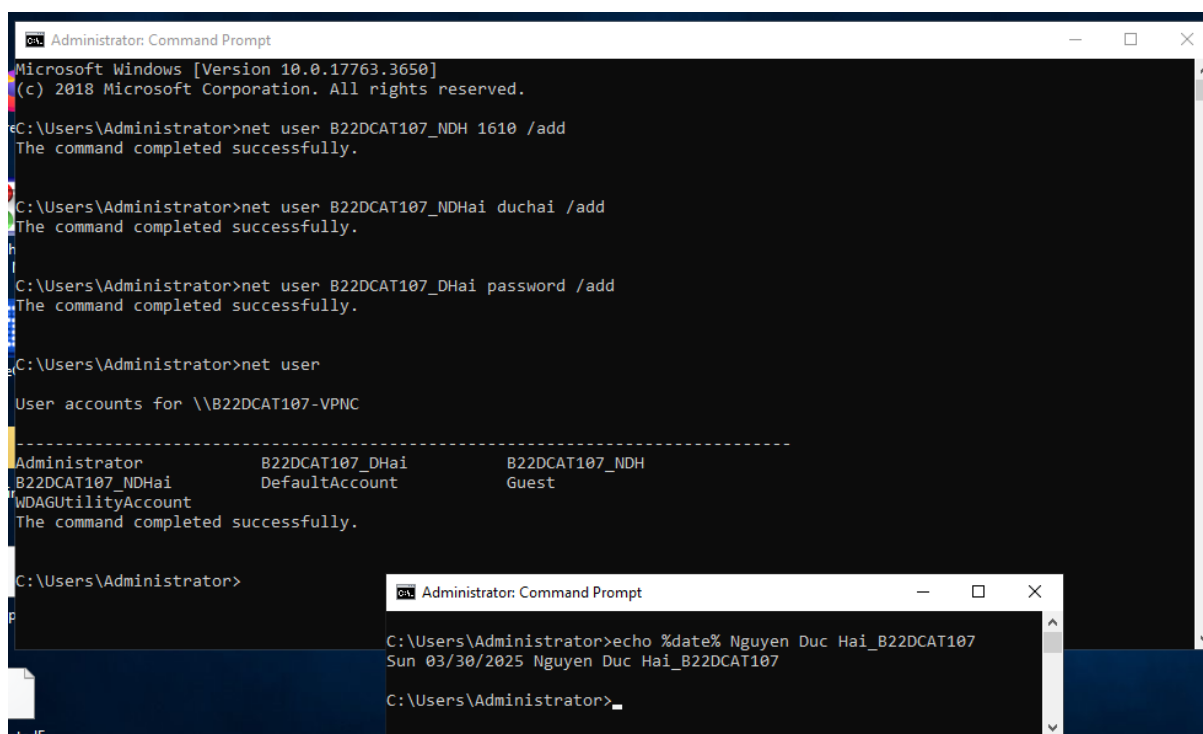


Hình 4 – Cài đặt thành công các công cụ

Tạo các User với mật khẩu có độ phức tạp khác nhau:

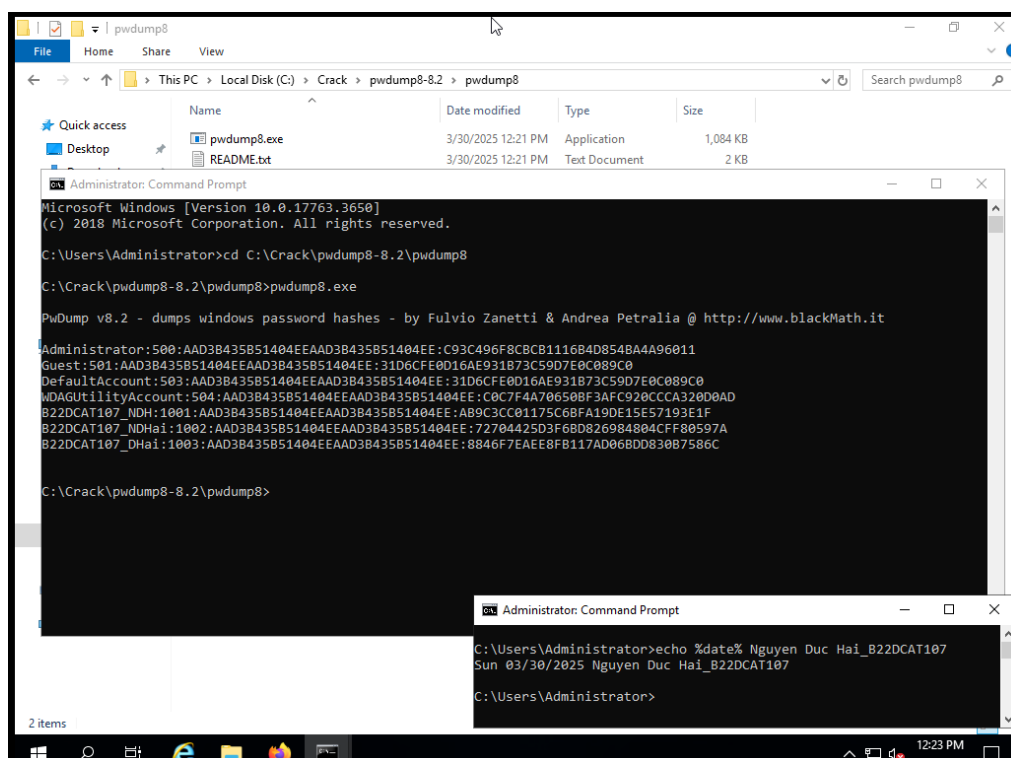
***net user <username> <password> /add***

Kiểm tra lại các user vừa tạo: ***net user***



Hình 5 – Tạo các user theo yêu cầu

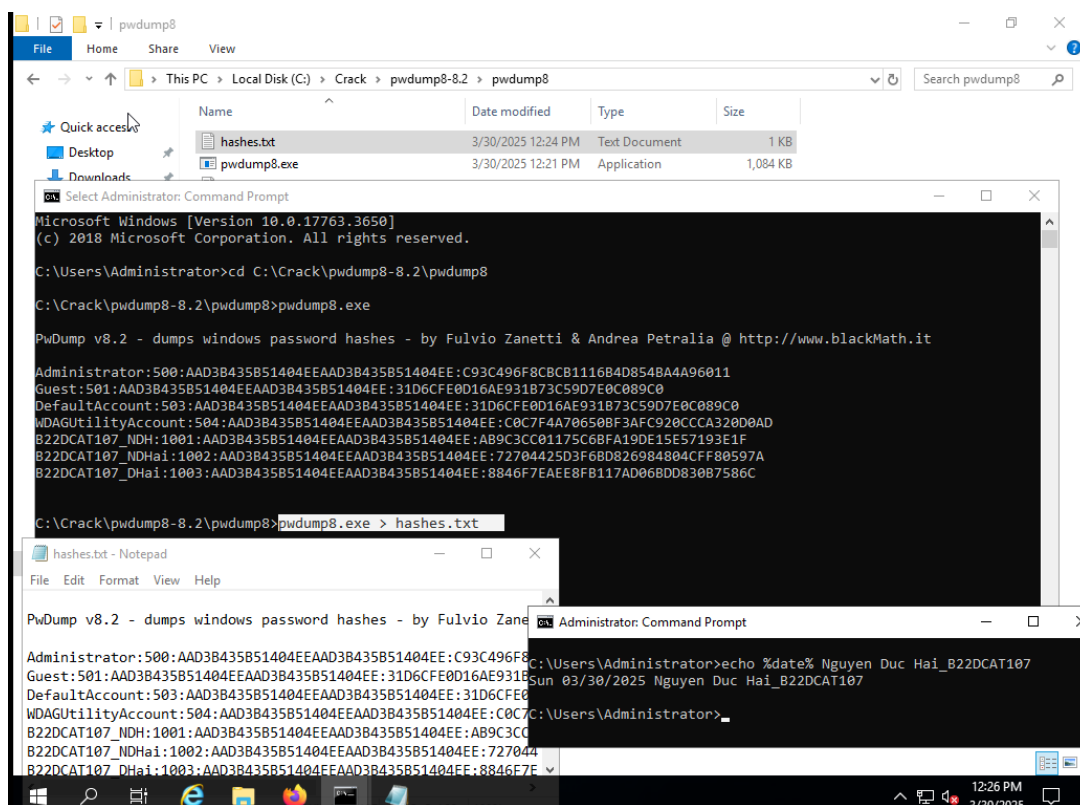
Sử dụng PWDUMP8 để tạo các hàm băm mật khẩu cho các user.



Hình 6 – Sử dụng công cụ PWDUMP8

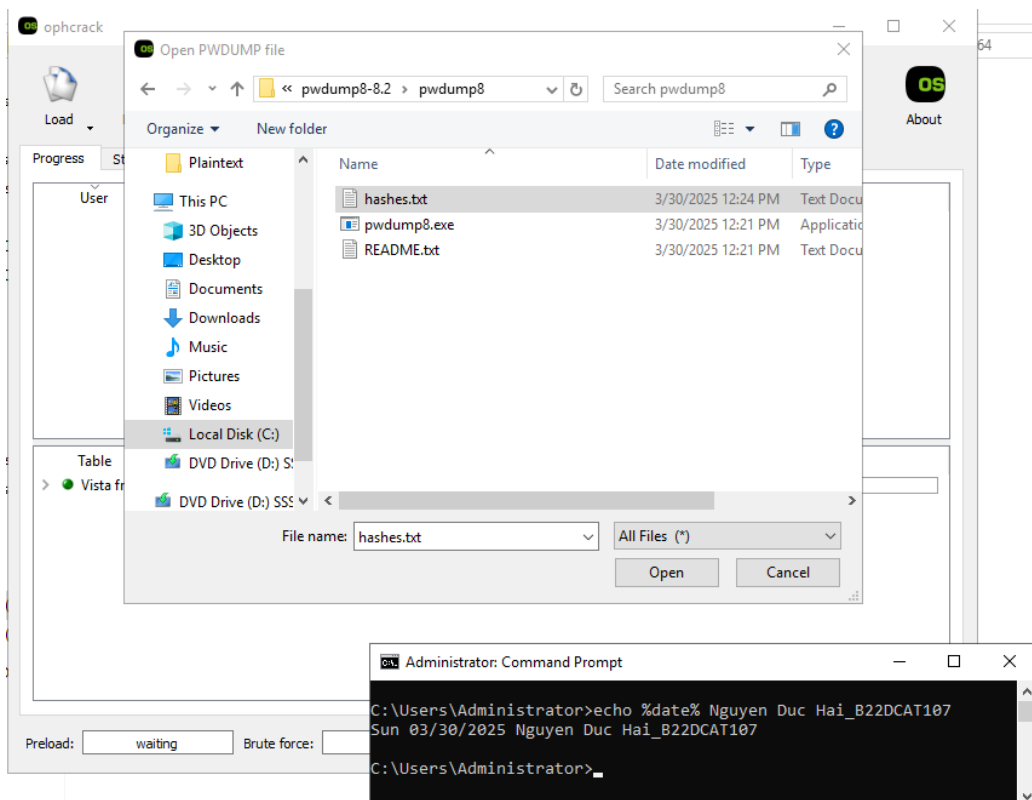
Sử dụng lệnh sau để lưu kết quả chạy chương trình ra file:

***pwdump8.exe > hashes.txt***



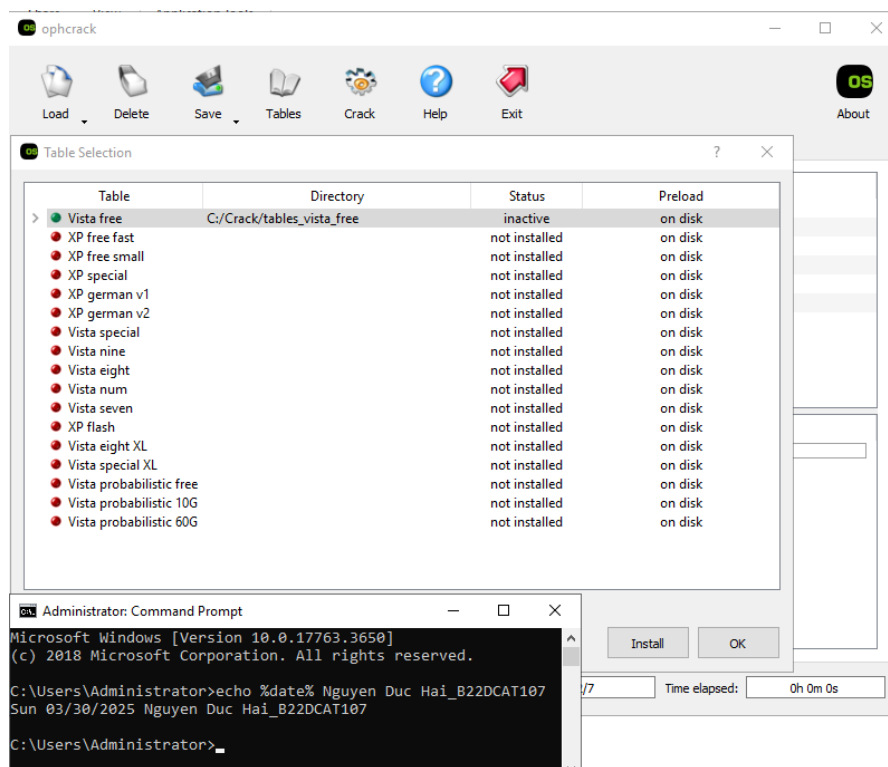
Hình 7 – Lưu các hàm băm ra file

Load file chứa các hàm băm vào công cụ Ophcrack.



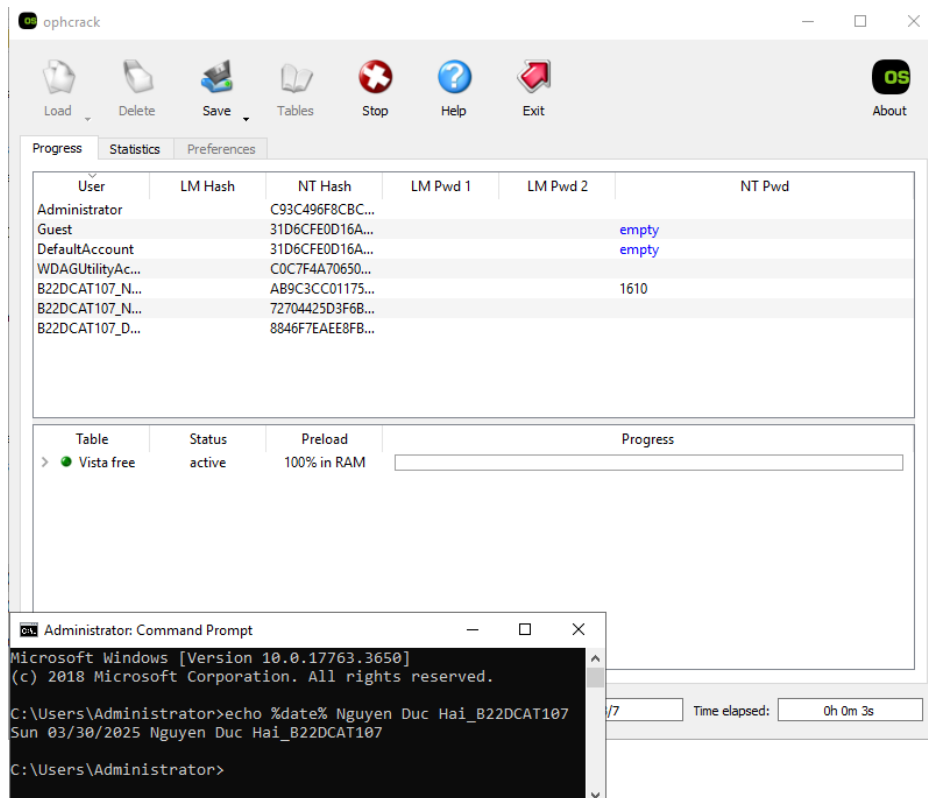
Hình 8 – Load file được tạo vào Ophcrack

Insert table đã tải từ trước.



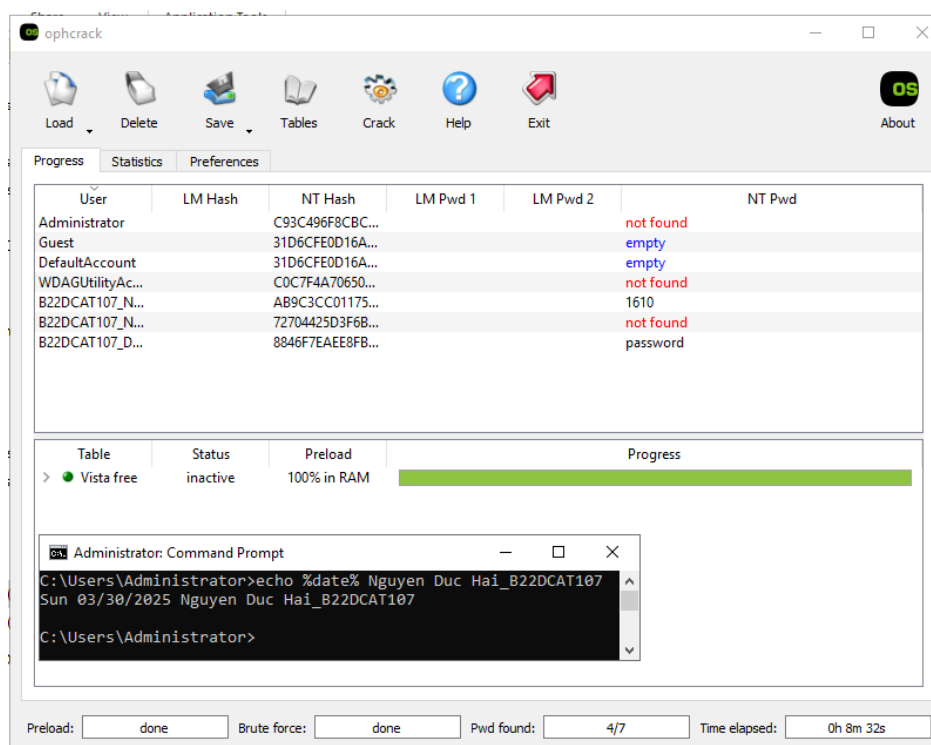
Hình 9 – Insert table vào Ophcrack

Chọn crack để bắt đầu bẻ khóa mật khẩu.



Hình 10 – Bắt đầu bẻ khóa mật khẩu

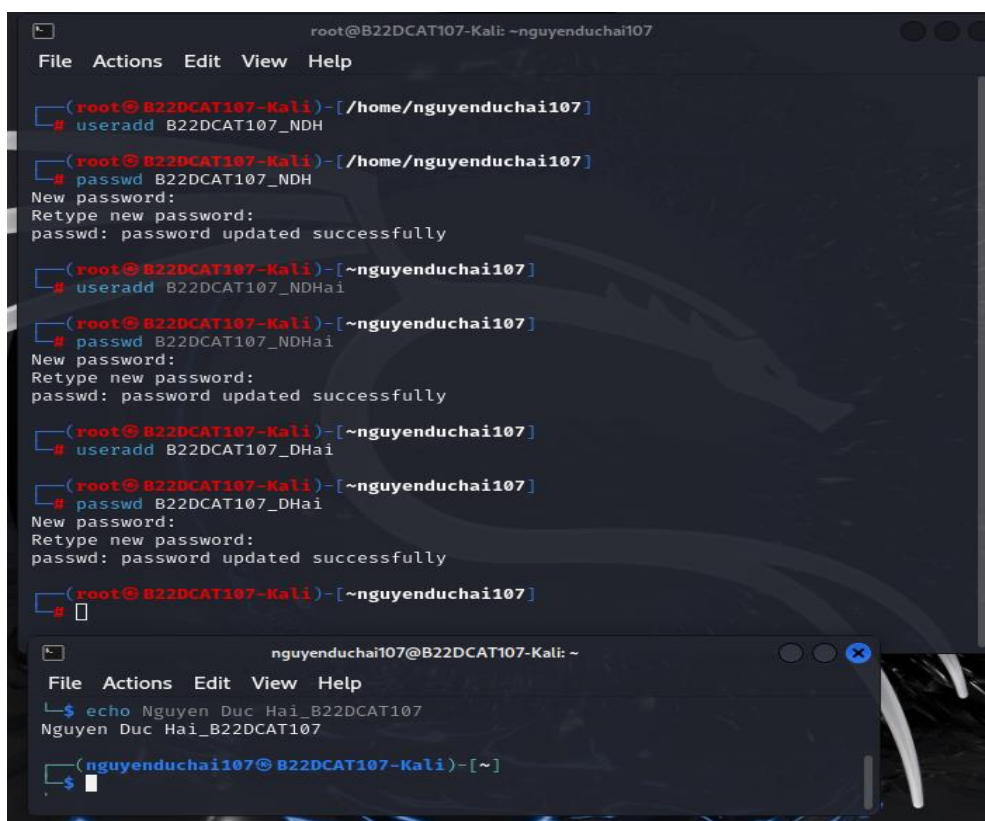
Sau khi quá trình bẻ khóa kết thúc ta có thể thấy được các mật khẩu không đảm bảo an toàn, user **B22DCAT107\_ND**Hai có độ phức tạp cao hơn nên không thể bẻ khóa.



Hình 11 – Kết quả sau khi chạy Ophcrack

### 2.2.2 Crack mật khẩu trên hệ điều hành Linux

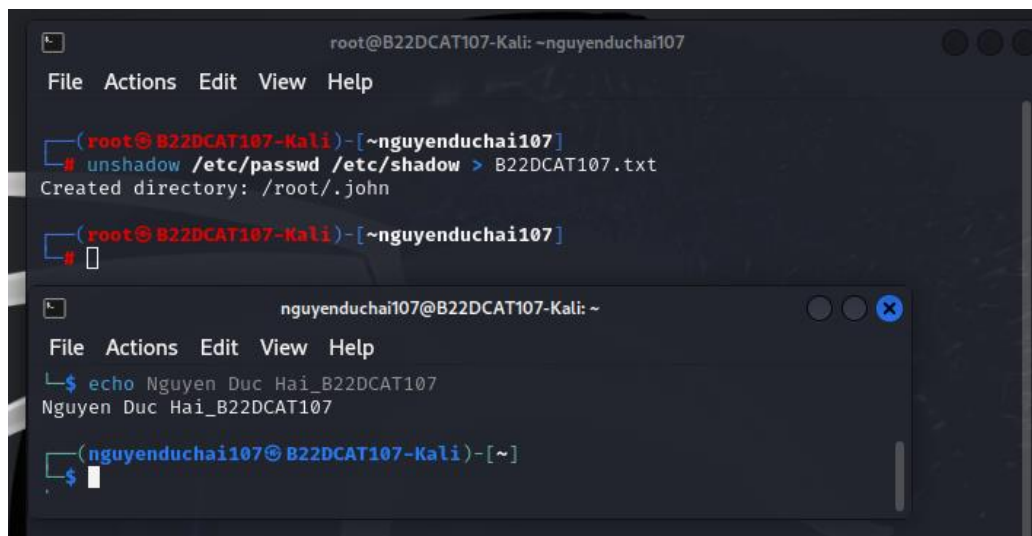
Tạo các user với mật khẩu theo yêu cầu.



Hình 12 – Tạo các user theo yêu cầu

Kết hợp 2 file passwd và shadow để sử dụng cho quá trình crack mật khẩu của John the Ripper:

***unshadow /etc/passwd /etc/shadow > B22DCAT107.txt***



```
root@B22DCAT107-Kali: ~nguyenduchai107
File Actions Edit View Help

(root@B22DCAT107-Kali)-[~nguyenduchai107]
# unshadow /etc/passwd /etc/shadow > B22DCAT107.txt
Created directory: /root/.john

(root@B22DCAT107-Kali)-[~nguyenduchai107]
#

nguyenduchai107@B22DCAT107-Kali: ~
File Actions Edit View Help

$ echo Nguyen Duc Hai_B22DCAT107
Nguyen Duc Hai_B22DCAT107

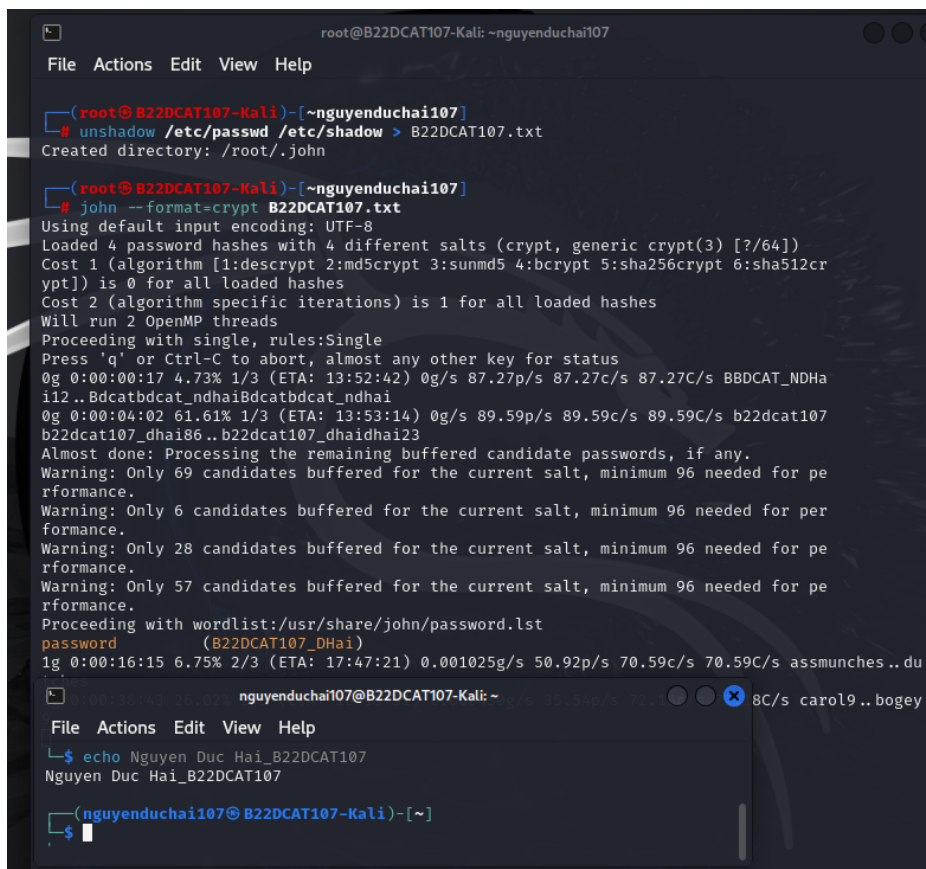
(nguyenduchai107@B22DCAT107-Kali)-[~]
$
```

Hình 13 – Kết hợp 2 file passwd và shadow

Sử dụng John the Ripper tiến hành crack mật khẩu từ file vừa tạo:

***john --format=crypt B22DCAT107.txt***

- Crack thành công mật khẩu 8 ký tự.



```
root@B22DCAT107-Kali: ~nguyenduchai107
File Actions Edit View Help

(root@B22DCAT107-Kali)-[~nguyenduchai107]
# unshadow /etc/passwd /etc/shadow > B22DCAT107.txt
Created directory: /root/.john

(root@B22DCAT107-Kali)-[~nguyenduchai107]
# john --format=crypt B22DCAT107.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (crypt, generic crypt(3) [?/64])
Cost 1 (algorithm [1:descrypt 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:17 4.73% 1/3 (ETA: 13:52:42) 0g/s 87.27p/s 87.27c/s B22DCAT_NDHa
i12..B22DCAT_NDHa1B22DCAT_NDHa1
0g 0:00:04:02 61.61% 1/3 (ETA: 13:53:14) 0g/s 89.59p/s 89.59c/s B22DCAT107
b22dc107_dhai86..b22dc107_dhai23
Almost done: Processing the remaining buffered candidate passwords, if any.
Warning: Only 69 candidates buffered for the current salt, minimum 96 needed for pe
rformance.
Warning: Only 6 candidates buffered for the current salt, minimum 96 needed for pe
rformance.
Warning: Only 28 candidates buffered for the current salt, minimum 96 needed for pe
rformance.
Warning: Only 57 candidates buffered for the current salt, minimum 96 needed for pe
rformance.
Proceeding with wordlist:/usr/share/john/password.lst
password (B22DCAT107_DHai)
1g 0:00:16:15 6.75% 2/3 (ETA: 17:47:21) 0.001025g/s 50.92p/s 70.59c/s 70.59c/s assmunches..du
8C/s carol9..bogey

nguyenduchai107@B22DCAT107-Kali: ~
File Actions Edit View Help

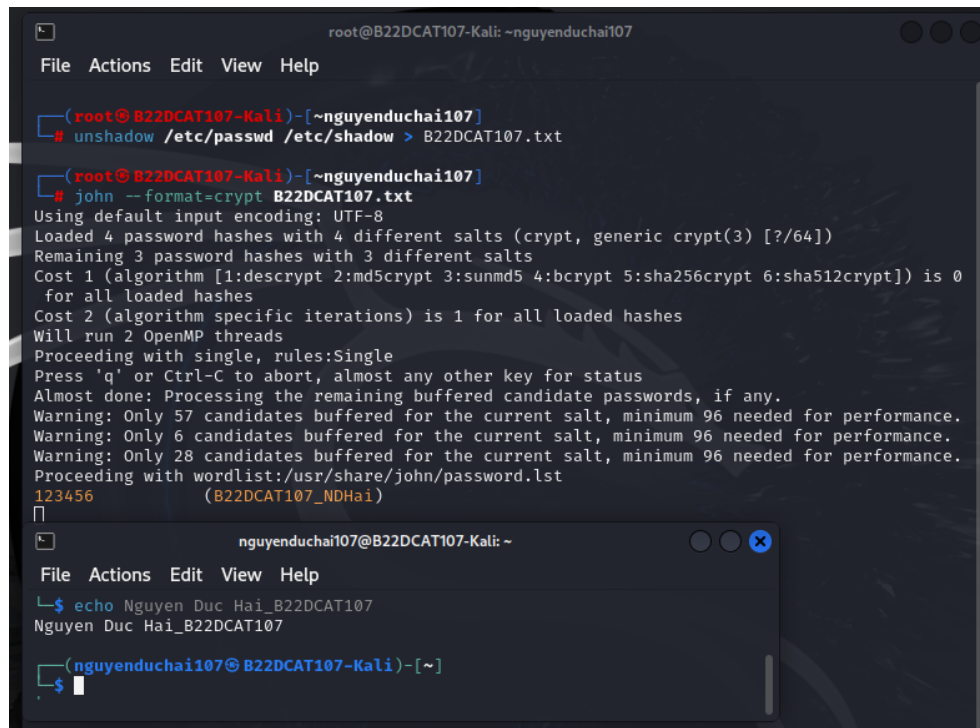
$ echo Nguyen Duc Hai_B22DCAT107
Nguyen Duc Hai_B22DCAT107

(nguyenduchai107@B22DCAT107-Kali)-[~]
$
```

Hình 14 – Crack thành công mật khẩu 8 ký tự



- Crack thành công mật khẩu 6 kí tự.



```

root@B22DCAT107-Kali: ~nguyenduchai107
File Actions Edit View Help

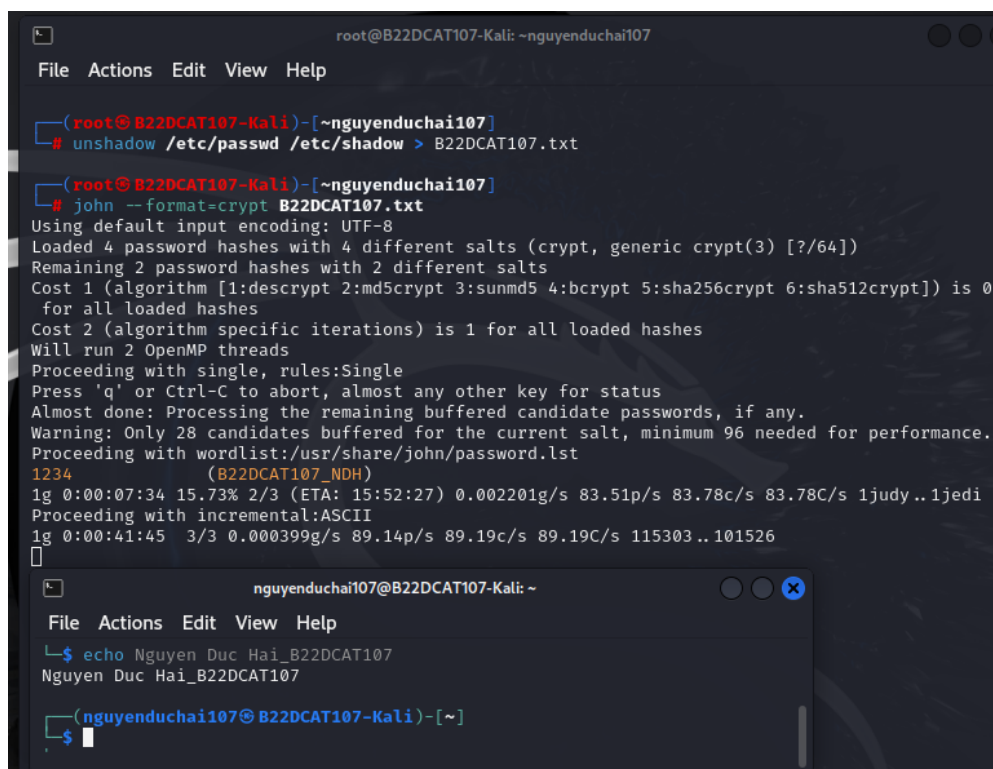
(root@B22DCAT107-Kali)-[~nguyenduchai107]
# unshadow /etc/passwd /etc/shadow > B22DCAT107.txt

(root@B22DCAT107-Kali)-[~nguyenduchai107]
# john --format=crypt B22DCAT107.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (crypt, generic crypt(3) [?/64])
Remaining 3 password hashes with 3 different salts
Cost 1 (algorithm [1:descrypt 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0
for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Warning: Only 57 candidates buffered for the current salt, minimum 96 needed for performance.
Warning: Only 6 candidates buffered for the current salt, minimum 96 needed for performance.
Warning: Only 28 candidates buffered for the current salt, minimum 96 needed for performance.
Proceeding with wordlist:/usr/share/john/password.lst
123456 (B22DCAT107_NDHai)

```

Hình 15 – Crack thành công mật khẩu 6 kí tự

- Crack thành công mật khẩu 4 kí tự.



```

root@B22DCAT107-Kali: ~nguyenduchai107
File Actions Edit View Help

(root@B22DCAT107-Kali)-[~nguyenduchai107]
# unshadow /etc/passwd /etc/shadow > B22DCAT107.txt

(root@B22DCAT107-Kali)-[~nguyenduchai107]
# john --format=crypt B22DCAT107.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (crypt, generic crypt(3) [?/64])
Remaining 2 password hashes with 2 different salts
Cost 1 (algorithm [1:descrypt 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0
for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Warning: Only 28 candidates buffered for the current salt, minimum 96 needed for performance.
Proceeding with wordlist:/usr/share/john/password.lst
1234 (B22DCAT107_NDH)
1g 0:00:07:34 15.73% 2/3 (ETA: 15:52:27) 0.002201g/s 83.51p/s 83.78c/s 83.78C/s 1judy..1jedi
Proceeding with incremental:ASCII
1g 0:00:41:45 3/3 0.000399g/s 89.14p/s 89.19c/s 89.19C/s 115303..101526

```

Hình 16 – Crack thành công mật khẩu 4 kí tự



## TÀI LIỆU THAM KHẢO

- [1] Đinh Trường Duy, Phạm Hoàng Duy, Bài giảng Hệ điều hành Windows và Linux/Unix, Học viện Công Nghệ Bưu Chính Viễn Thông, 2022.
- [2] Tom Carpenter, Microsoft Windows Server Operating System Essentials, Sybex, 2011.
- [3] Chương 2, Giáo trình Cơ sở an toàn thông tin, Học viện Công Nghệ Bưu Chính Viễn Thông, 2020 của tác giả Hoàng Xuân Dậu.
- [4] [John the Ripper là gì?](#)
- [5] [Tìm hiểu về các công cụ khai thác bảo mật trong kali linux](#)
- [6] [Pwddump là gì?](#)